ARNOBOT

ArnoBot — Technische overdracht

Dit document beschrijft de volledige technische structuur van ArnoBot. Het is bedoeld voor een developer die het project overneemt zonder voorkennis. Bewaar dit document in de GitHub-repo (`docs/TECHNICAL_HANDOVER.md`) zodat het altijd naast de code staat.

Sectie **AI-modellen** en **Package-versies** worden automatisch bijgewerkt op de 1e van elke maand door de `update-handover` cron.

Laatste automatische update: 2026-11-01

Wat doet de app

ArnoBot is een AI-coachingplatform voor salesprofessionals. Gebruikers voeren gesprekken met een op maat gemaakte versie van Claude (Anthropic). Na meerdere gesprekken genereert de app een coachingrapport met scores op mindset, systeem en actie. Daarnaast kan een gebruiker oefenen in een live sparring-modus (AI speelt een lastige gesprekspartner) en heeft de app een teammodule waarmee managers inzicht krijgen in hun verkopers, automatisch 1:1-agenda's laten genereren en maandelijks een teambrede "Spotlight"-analyse ontvangen.

Live URL: https://arno.bot **GitHub:** https://github.com/arnoceo-ops/arnobot **Vercel project:** arnobot (op account arnoceo-ops)

Tech stack

Component	Technologie	Versie
Framework	Next.js (App Router)	^16
Taal	TypeScript	^5
Authenticatie	Clerk	^7
Database	Supabase (PostgreSQL, RLS aan op alle tabellen)	^2
Hosting	Vercel	Pro
AI (chat/coaching)	Anthropic Claude	via SDK ^0.115
Embeddings + rerank (RAG)	VoyageAI	rauwe fetch, geen SDK
Spraakherkenning	OpenAI Whisper	rauwe fetch, geen SDK
Tekst-naar-spraak (Voice)	ElevenLabs	rauwe fetch, geen SDK
E-mail	Resend	^6
Rate limiting	Upstash Redis	^1 / ^2
Foutmonitoring	Sentry (`@sentry/nextjs`)	^10
Productanalyse (publiek + ingelogd)	PostHog (`posthog-js`)	^1
Admin/ops-notificaties	Telegram Bot API	directe fetch
Boekingswebhook	Calendly	inkomend webhook, geen SDK
PDF export	jsPDF + @react-pdf/renderer	^4
Mobiele wrapper (in ontwikkeling)	Capacitor (Android)	^8

Verwijderd (2026-08-01): Sanity, next-sanity en @portabletext/react zijn volledig verwijderd. De kennisbank draait sindsdien uitsluitend op de eigen `blog_chunks`-tabel (RAG via VoyageAI), niet meer op een CMS.

Hoe deployment werkt

Elke `git push origin master` triggert automatisch een Vercel-deploy. Er is geen handmatige stap nodig.

1. Code staat op GitHub (`arnoceo-ops/arnobot` , branch `master`)
2. Vercel luistert op die branch en bouwt automatisch
3. Build: `next build --webpack`
4. Environment variables staan in het Vercel-dashboard (zie sectie Externe diensten)
5. Cron jobs worden beheerd via `vercel.json` in de root van de repo

Rollback: In het Vercel-dashboard kun je op elk moment terugzetten naar een eerdere deployment. Dit is de snelste manier om een kapotte deploy ongedaan te maken.

Lokale ontwikkeling:

```
npm install
npm run dev
```

Vereist een `.env.local` bestand met alle environment variables (zie Externe diensten).

Gebruikersflow

De volledige flow van aanmelding tot coaching:

```
Aanmelding (arno.bot/aanmelden of LinkedIn OAuth)
    ↓
approved_users record aangemaakt (pending_ prefix bij e-mailaanmelding, direct bij LinkedIn)
    ↓
Eerste inlog → /bot/profiel (intake/onboarding, onboarding_done gezet)
    ↓
/bot (hoofdchat — gesprekken via arnobot_rds_logs + arnobot_blog_sessions)
    ↓
Elke sessie → /api/bot/session-end (synthese: title + summary + feiten + uitdaging + entiteiten-extractie)
    ↓
Na 5+ gesprekken → /api/cron/auto-analyse (analyse aangemaakt in arnobot_analyses, zichtbaar op /bot/analyses)
    ↓
/bot/coaching → /api/bot/coaching (coachingrapport in arnobot_coaching + arnobot_coaching_history)
    ↓
/bot/analyses (alle gesprekken + analyses zichtbaar)
```

Sparring-modus (aanvullend):

```
/bot/sparren → /api/sparring/open (AI opent in karakter)
    ↓
/api/sparring/chat (live oefengesprek, AI blijft in karakter)
    ↓
/api/sparring/debrief (analyse na afloop, opslag in arnobot_sparring_sessions)
```

Teamflow (aanvullend):

```
Manager maakt team aan → /api/bot/team/create (vereist command_manager-vlag)
    ↓
Teamleden accepteren uitnodiging → /bot/team/join
    ↓
Manager ziet teamoverzicht → /bot/team
    ↓
Manager vraagt 1:1-agenda op per lid → /api/bot/team/1on1
    ↓
Manager slaat notitie op → /api/bot/team/1on1/save
    ↓
Maandelijks: Spotlight (teamanalyse) → /api/bot/team/spotlight
    ↓
Manager eigen zelfcoaching (Strategy People Execution) → /api/bot/team/zelfcoaching
```

Pagina-overzicht

Bot-pagina's (achter Clerk-login, `/bot/*`)

Pagina	Pad	Functie
Hoofdchat	`/bot`	Centrale gesprekspagina met ArnoBot. Desktop-only linkje verwijst naar de community-vragenpagina
Community vragen	`/bot/cgq`	Vragenraster (Strategy/People/Execution-toggle + community-vragen), sinds 28 augustus 2026 losgekoppeld van `/bot` zelf om die pagina kaler te houden, op 29 augustus 2026 hernoemd van `/bot/voorbeeldvragen` naar `/bot/cgq` ("community generated questions"). Zelfde component/chatlogica als `/bot`, alleen desktop bereikbaar. Gesprekken die hier starten tellen standaard niet mee in coachingsdiagnose/analyses, tenzij de gebruiker dat via een expliciete opt-in-toestemming aanvinkt
Profiel / intake	`/bot/profiel`	Korte onboarding-intake bij eerste inlog (rol, markt, wat verkoop je, ideale klant, dealgrootte, salescyclus, ervaring, uitdaging; solo- en teamvariant iets afwijkend). Bij afronden wordt `trial_start` heraankerd op dat moment. Daarna dezelfde pagina om de salescontext te bekijken/aanpassen
Coaching	`/bot/coaching`	Coachingrapport aanvragen en bekijken (Pro-only, upsell voor Basic)
Analyses	`/bot/analyses`	Archief van gesprekken + AI-analyses + blogsuggesties
Sparren	`/bot/sparren`	Live rollenspel/oefenmodus tegen een AI-tegenstander
Gesprek boeken	`/bot/gesprek`	Gate/CTA om een 1-op-1 gesprek met Arno te boeken
Doorgaan	`/bot/doorgaan`	Doorstroompagina naar de boekingslink
Herstart	`/bot/herstart`	Reactivatiepagina na abonnementsprobleem (winback/second-trial)
Account	`/bot/account`	Abonnement, referral, data-export, account verwijderen
Upgrade	`/bot/upgrade`	Upgrade-CTA (mailto-aanvraag) voor Pro-features
Uitnodiging vereist	`/bot/uitnodiging-vereist`	Blokkeerscherm voor teamlicentie zonder geldige invite
Team	`/bot/team`	Teamoverzicht (alleen managers)
Team aansluiten	`/bot/team/join`	Teamuitnodiging accepteren
Teamlid	`/bot/team/lid/[userId]`	Individueel lid: scores, gedeelde analyses, 1:1-geschiedenis

Admin-pagina's (`/bot/admin/*`, cookie-gated via `arnobot_admin`)

Login via `/bot/admin/login` (`ARNOBOT_ADMIN_KEY`).

Pagina	Functie
`/bot/admin`	Overzicht alle vraag/antwoord-logs, filters, PDF-download
`/bot/admin/gebruikers`	Gebruikersbeheer: health-score, trial/plan, command-manager-toggle, SD-agent-koppeling
`/bot/admin/emails`	E-mail templates + crons testen
`/bot/admin/emails/overzicht`	E-mail lifecycle overzicht (printbaar)
`/bot/admin/evaluaties`	Negatieve chatantwoord-beoordelingen bekijken
`/bot/admin/analyse`	AI-briefing per gebruiker (individueel of teambaas) op basis van alle beschikbare data, met doorvraagchat. Ter voorbereiding op een gesprek dat Arno met die persoon gaat voeren
`/bot/admin/idee`	Redactionele blogbriefing op basis van gesprekken
`/bot/admin/stats` (tab BLOG)	Blogstatistieken (`BlogStats.tsx` , gedeelde onderdelen in `StatsUi.tsx`): abonnees, conversie bevestigen/afmelden, groei per week, verzending en dagbudget, bezoek en klikken op Start gratis vanaf de blog, per artikel (verzonden, wachtrij, mislukt, geopend, geklikt, bezoeken), populariteit per blog (`BlogPopulariteit.tsx` : meest en minst geopend, schakelaar 30 dagen of totaal, alle blogs 10 per keer, CSV), "wie doet wat" met abonnees die klikken of openen en of ze al gebruiker zijn, en een aanmeldingenlijst met CSV. Blogtellingen tellen alleen echte blogpaden (één niveau onder `/blog`). Alles zijn exacte head-counts in de database
`/bot/admin/blog`	POSTS: de publieke blog beheren. Lijst + editor (`/bot/admin/blog/[id]` , `nieuw` voor een nieuwe post) met live Markdown-voorbeeld, afbeeldingen plakken/slepen, hashtags met suggesties, concept/publiceren/inplannen, "verstuur naar abonnees" en testmail naar jezelf, lokale noodback-up
`/bot/admin/meta-analyse`	Zelfbeoordeling ArnoBot + jurering door vijf fictieve sales-experts
`/bot/admin/status`	Systeemstatus-dashboard (Instatus-uptime, LinkedIn-fallback toggle)
`/bot/admin/voice-test`	Testomgeving voor de ElevenLabs voice/TTS-integratie
`/bot/admin/widget`	Losse log-viewer voor de publieke embed-widget
`/bot/admin/stats`	Statistiekendashboard (health-score, gebruikstrends, funnel)
`/bot/admin/kennisbank`	Kennisbank-beheer: RSS-bronnen, chunks per bron

Abacus (kostencalculator, cookie-gated via `arnobot_kosten`)

Pagina	Functie
`/abacus`	Interne kostendashboard/-calculator
`/abacus/login`	Wachtwoordscherm (`ARNOBOT_KOSTEN_KEY`)

Agents / Sales Development (cookie-gated via `arnobot_sd_verdien`)

Backend/bestandsnamen heten "sd-verdien", de publieke route is `/agents` .

Pagina	Functie
`/agents`	Verdienoverzicht voor sales-development-agents (admin-cookie geeft ook toegang)
`/agents/login`	Wachtwoordscherm (`SD_VERDIEN_PASSWORD` , admin-key werkt ook)

Publieke pagina's

Pagina	Pad	Functie
Landingspagina	`/`	Marketingpagina, redirect naar `/bot` als al ingelogd
Prijzen	`/prijzen`	Prijzenpagina (Basic/Pro/Team)
Aanmelden	`/aanmelden`	Zet referral-/SD-attributiecookies, redirect naar `/sign-in`
Sign in	`/sign-in`	Clerk sign-in (LinkedIn OIDC)
Sign in (enterprise)	`/sign-in/enterprise`	Enterprise SSO via e-maildomein
Sign in (intern)	`/testlogin`	Verborgen wachtwoord-login, alleen Arno's eigen testaccount (tot 2026-10-13 op `/sign-in/intern`). Bij "login kapot": controleer eerst `expires_at` in `approved_users` (zie `lib/internalTestAccounts.ts`), niet meteen Clerk/routing verdenken
Sign up	`/sign-up`	Clerk sign-up (LinkedIn OIDC)
SSO callback	`/sso-callback`	Clerk SSO-redirect-afhandeling
Privacy	`/privacy`	Privacyverklaring
Voorwaarden	`/voorwaarden`	Gebruiksvoorwaarden
Referral-spelregels	`/referrals`	Spelregels referralprogramma
Teamaanvraag	`/team`	Publiek leadformulier + prijscalculator voor teamlicenties (los van `/bot/team`)
ArnoLive	`/arnolive`	Marketingpagina "ARNOLIVE"/"ARNOPRIME"-lidmaatschap, eigen (crème/oranje) huisstijl
Opt-out	`/optout/[token]`	Afmelden voor marketingmails
Gedeeld gesprek	`/gesprek/[token]`	Publieke, view-only weergave van een gedeeld gesprek
Beveiliging PDF	via `/api/beveiliging-pdf`	Downloadbaar beveiligingsdocument
Blog overzicht	`/blog`	Publieke blog over ArnoBot (marketingstijl), met hashtagchips (naar de hashtagpagina's), doorzoekbaar archief (`BlogArchive`: zoeken op hashtag of trefwoord in de browser op de geladen lijst via `lib/blogSearch.ts`, 12 kaarten per keer met "Toon meer", zoekterm in de URL als `?q=`) en abonneerblok. Posts leven in Supabase (`arnobot_blog_posts`), beheerd via `/bot/admin/blog`
Blog artikel	`/blog/[slug]`	Artikel met JSON-LD, deelknoppen (LinkedIn via de deelpagina van LinkedIn zelf, plus link kopiëren, `ShareButtons.tsx`), CTA naar de trial (via `SignupCTA`, dus in de funnel meegeteld), abonneerblok en gerelateerde posts. Deelkaart per post: `app/blog/[slug]/opengraph-image.tsx` (1200 x 630, merkkaart met titel en hashtags, zonder omslagfoto, zelfde lettertypen en bundeling als `app/opengraph-image.tsx`). Onbekende slug stuurt (tijdelijk) door naar arno.blog, oude jaar- en `.html`-URL's staan als redirect in `next.config.ts`
Blog hashtag	`/blog/tag/[tag]`	Posts per hashtag. Minder dan 3 posts: `noindex`
Blog RSS	`/blog/feed.xml`	RSS 2.0 met volledige tekst

Pagina	Pad	Functie
Blog bevestigen	`/blog/bevestig/[token]`	Terugvalpagina voor double opt-in: bevestigt pas na een klik op de knop. De link in de mail wijst naar `/api/blog/bevestig?token=` (zie API), niet hierheen. Token in het pad: uitgesloten van pageview- en PostHog-tracking
Blog afmelden	`/blog/afmelden/[token]`	Zelfde patroon, knop i.p.v. directe actie

Let op: `/team` (publiek leadformulier) en `/bot/team` (ingelogd managersdashboard) zijn twee verschillende pagina's met bijna dezelfde naam, niet met elkaar verwarren.

API-routes

Ruim 110 routes in `app/api/**/route.ts`. Onderstaande lijst dekt ze allemaal, gegroepeerd per functiegebied.

Kern-AI-routes

Route	Doel
`/api/chat`	Hoofdgesprek met ArnoBot (streaming). Bij `stop_reason: max_tokens` volgt automatisch één vervolgstream in dezelfde respons. Persona en regels in `lib/systemPrompt.ts`, o.a. de harde grens op het uitschrijven van een volledig plan (sectie EIGEN PLANNEN EN DOCUMENTEN) en "één richting, geen draaiboek". Plangegevens komen als feiten met voorvoegsel "Plan:" in `arnobot_blog_sessions.feiten` (gezet door `session-end`) en worden via `planHistorieBlok` in `lib/analyseContext.ts` aan analyses en coaching gevoed
`/api/chat-voice`	Voice-variant van het hoofdgesprek (eigen rate limit + plancheck)
`/api/bot/session-end`	Synthese aan einde gesprek (titel/samenvatting/feiten/uitdaging/entiteiten)
`/api/admin/geheugen-preview`	Toont exact de geheugen- en gebruikerscontext die de hoofdchat voor een gebruiker in de prompt zet (zelfde code, `lib/geheugenContext.ts`), zonder model-aanroep en zonder writes. Alleen met admin-cookie. Optioneel `negeerSessieIds` om een eerder moment na te spelen. Gebruikt door `scripts/check-geheugen-oud.mjs`
`/api/bot/sessions`	Ruwe logs groeperen tot sessies, embedding + entiteiten-extractie
`/api/bot/sessions/search`	AI-filter op eigen gesprekken
`/api/bot/session`	Eén sessie ophalen/verwijderen
`/api/bot/coaching`	Coachingrapport genereren (hoofdsynthese)
`/api/bot/coaching-analyse`	Nieuwe analyse genereren voor `/bot/analyses` (alleen `sessionIds`). Prompt en blokken in `lib/analyseContext.ts`, gedeeld met `cron/auto-analyse`
`/api/bot/coaching-analyses`	Eerdere analyses ophalen (lijst)
`/api/bot/coaching-precheck`	Check of er genoeg materiaal is voor coaching
`/api/bot/coaching-history`	Coaching-geschiedenis (scores/diagnoses per keer)
`/api/bot/coaching-scores`	Losse scoreverloop (mindset/systeem/actie/MSA)
`/api/bot/uitdaging`	"Thought of the day" op de coachingpagina: één korte inspirerende mindsetgedachte per dag. Weekend altijd generiek, doordeweeks gepersonaliseerd op patronen vanaf 3 gesprekken
`/api/bot/verfijn`	Vraag/antwoord scherper herformuleren via AI
`/api/bot/actieopvolging`	Open actie ophalen + reflexief-klik-detectie
`/api/bot/hint-status`	Telt gesprekken/dagen sinds laatste analyse/coaching
`/api/bot/openers`	Vaste set gespreksopeners ophalen
`/api/bot/backfill-embeddings`	Ontbrekende embeddings aanvullen voor RAG
`/api/bot/search-linkedin-profile`	AI + web_search zoekt LinkedIn-profiel (admin-only ondanks `/bot`-pad)
`/api/transcribe`	Spraak naar tekst (OpenAI Whisper)
`/api/tts-voice`	Tekst naar spraak (ElevenLabs, rate-limited, plancheck)

Sparring

Route	Doel
`/api/sparring/open`	Opent een sparring-oefengesprek
`/api/sparring/chat`	Live sparring-gesprek, AI blijft in karakter
`/api/sparring/debrief`	Debrief/analyse na afloop, opslag
`/api/bot/sparring-history`	Sparring-geschiedenis ophalen + favoriet togglen

Team

Route	Doel
`/api/bot/team/create`	Team aanmaken (vereist command_manager)
`/api/bot/team/join`	Team aansluiten via uitnodigingscode (max 25 leden)
`/api/bot/team/status`	Teamstatus ophalen
`/api/bot/team/dashboard`	Managersdashboard-data per lid
`/api/bot/team/scores`	Geaggregeerde teamscores
`/api/bot/team/lid`	Ledenbeheer (manager-only)
`/api/bot/team/1on1`	1:1-agenda genereren
`/api/bot/team/1on1/save`	1:1-notitie + agenda opslaan
`/api/bot/team/1on1/note`	Notitie/actie-status bijwerken
`/api/bot/team/ritme`	Minimale 1:1-interval instellen
`/api/bot/team/notifications`	Teamnotificaties ophalen
`/api/bot/team/notifications/read`	Notificaties als gelezen markeren
`/api/bot/team/share-analyse`	Teamlid deelt analyse met manager
`/api/bot/team/spotlight`	Maandelijkse teamanalyse (Spotlight)
`/api/bot/team/zelfcoaching`	Zelfcoaching voor de teambaas zelf (met cooldown)

Gebruikersbeheer

Route	Doel
`/api/bot/profiel`	Profiel opslaan + onboarding_done zetten (en bij de eerste keer `trial_start` heraankeren)
`/api/bot/plan`	Eigen plan + command_manager-vlag ophalen
`/api/bot/export`	Alle eigen data exporteren (AVG)
`/api/bot/delete-account`	Verwijderverzoek account
`/api/bot/referral`	Eigen referralcode ophalen/genereren
`/api/bot/cancel-subscription`	Abonnement opzeggen (self-service)
`/api/bot/herstart`	Reactivatie-eligibility bepalen (regels in `lib/herstart.ts`: na twee proefperiodes zonder betalen pas na 12 maanden weer een gratis proefperiode, betalen kan altijd)
`/api/bot/welcome-done`	Welkomstscherm als gezien markeren
`/api/bot/set-app-password`	Wachtwoord instellen via Clerk backend-API
`/api/bot/share-session`	Gesprek deelbaar maken via token-URL
`/api/bot/events`	Whitelisted clientevents loggen
`/api/bot/response-feedback`	Duim omhoog/omlaag op een antwoord
`/api/optout`	Marketingmail-opt-out verwerken (HMAC-signature-check)

Admin

Route	Doel
`/api/arnobot-admin-login`	Admin-login (cookie, IP-rate-limit)
`/api/admin/logout`	Admin-cookie wissen
`/api/admin/blog/posts`	GET lijst, POST nieuwe blogpost (validatie van lengtes, slug-uniekheid en toegestane afbeeldings-URL, geen streepjescontrole op de tekst)
`/api/admin/blog/posts/[id]`	PUT bijwerken (publiceren, inplannen, naar concept), DELETE. Verstuurt bij publiceren met vinkje eenmalig naar abonnees (`notified_at`)
`/api/admin/blog/upload`	Afbeelding naar de publieke bucket `blog-images` (PNG/JPG/WebP/GIF, max 5 MB, type via magic bytes, geen SVG)
`/api/admin/blog/subscribers`	GET een pagina blogabonnees (`offset` , `limit` max 100), nieuwste aanmelding eerst. Voedt de lijst "Aanmeldingen" in de blogstatistieken (50 per keer, knop voor de volgende 50, geen maximum)
`/api/admin/blog/popularity-export`	GET populariteit van alle gepubliceerde blogs als CSV (geopend en klikken op Start gratis, 30 dagen en totaal), via de SQL-functie `arnobot_blog_post_stats` (`docs/sql/2026-10-11-blog-populariteit.sql` , één groepeerquery over alle blogs, alleen service_role)
`/api/admin/blog/subscribers/export`	GET alle blogabonnees als CSV (gestreamd in blokken van 1000, UTF-8 met BOM, formule-injectie in cellen afgevangen)
`/api/admin/blog/test-send`	Stuurt de nieuw-artikel-mail naar arno@arno.bot
`/api/blog/subscribe`	PUBLIEK. Aanmelden voor blogmails (double opt-in). Ratelimit per IP (5/uur) en per adres (3/dag), honeypot, bot-UA-filter. Antwoord is altijd gelijk (lijst niet af te vragen). Nieuw of in afwachting: bevestigingsmail. Al bevestigd: mailtje "je bent al aangemeld" (`blog_al_aangemeld`), zodat niemand op een mail wacht die niet komt
`/api/blog/bevestig`	PUBLIEK. Doel van de link in de bevestigingsmail (GET). Echte klik van een mens (`Sec-Fetch-User: ?1` plus `Sec-Fetch-Mode: navigate` , `lib/blogConfirmGate.ts`) bevestigt direct en stuurt door naar `/blog?bevestigd=1` (of `0`). Scanners en browsers zonder die headers (Safari < 16.4) gaan naar `/blog/bevestig/[token]` met een knop, zonder iets te wijzigen
`/api/blog/confirm`	PUBLIEK. Bevestigt een aanmelding (POST, token), gebruikt door de terugvalpagina
`/api/blog/unsubscribe`	PUBLIEK. Afmelden, ook one-click (RFC 8058, `List-Unsubscribe-Post`)
`/api/admin/payment`	Betaling handmatig registreren (geen payment-provider gekoppeld, puur admin-actie)
`/api/admin/plan`	Plan van gebruiker aanpassen
`/api/admin/command-manager`	command_manager-vlag (teamaanmaak-recht) togglen
`/api/admin/sd-agent`	Sales-development-agent + attributiemethode koppelen
`/api/admin/export`	Logs exporteren als JSON (limiet 2000, sorteerbaar, gebruikt door `DownloadPdfButton.tsx`)
`/api/admin/export-csv`	Logs exporteren als CSV (limiet 100.000, directe downloadlink). Gedeelde auth/fetch-logica met `/api/admin/export` zit sinds 2026-08-21 in `lib/adminExport.ts` ; blijven twee routes omdat het gedrag verschilt (JSON voor client-side PDF-opbouw vs. directe CSV-file-download)

Route	Doel
`/api/admin/test-email`	E-mailtemplates + cron-mails handmatig testen/versturen
`/api/admin/test-telegram`	Telegram-bot testbericht sturen
`/api/admin/analyse`	GET: opgeslagen briefing per gebruiker ophalen. POST: briefing (opnieuw) genereren, opgeslagen in `arnobot_admin_analyses`
`/api/admin/analyse/users`	Lichte gebruikerslijst voor het zoekveld op `/bot/admin/analyse`, alleen gebruikers met minstens één gesprek, testaccounts uitgesloten
`/api/admin/analyse-chat`	Doorvragen op een briefing, niet-opgeslagen gesprek, zelfde databundel als de briefing zelf
`/api/admin/blogs-analyse`	AI-analyse voor blogideeën uit gesprekken
`/api/admin/feedback-analyse`	AI-analyse van negatief beoordeelde antwoorden
`/api/admin/offtopic-flags`	Offtopic-vlag als beoordeeld markeren
`/api/admin/kennisbank-chunks`	Kennisbank-chunks per URL ophalen/verwijderen
`/api/admin/trigger-rss-ingest`	RSS-ingest handmatig triggeren
`/api/admin/linkedin-fallback`	LinkedIn-loginfallback-modus aan/uit
`/api/admin/meta-analyse`	Handmatige meta-analyse (zelfbeoordeling + expertpanel + JOUW ANALYSE)
`/api/admin/meta-input`	Arno's input voor het jurypanel opslaan/ophalen
`/api/admin/voice-test/chat`	Voice-antwoord-tekst genereren voor handmatige stemtest
`/api/admin/voice-test/tts`	ElevenLabs TTS-streaming voor handmatige stemtest
`/api/bot/set-linkedin`	LinkedIn-url van gebruiker zetten (admin-cookie-auth ondanks `/bot`-pad)
`/api/test/email-preview`	Dev/test-only tool, stuurt alle templates naar Arno's eigen adres. Heeft wel een auth-check (`Bearer {CRON_SECRET}`), bewust op 2026-08-12 goedgekeurd als herbruikbare, admin-only diagnosetool (handmatig via curl/Postman, geen UI-knop, zie `scripts/check-orphan-routes.mjs`)

Sales-development

Route	Doel
`/api/sd-verdien-login`	Login voor het agents-verdienportaal (admin-wachtwoord werkt ook)
`/api/team-aanvraag`	Publiek offerteformulier voor Team-abonnement

Kosten/Abacus

Route	Doel
`/api/arnobot-kosten-login`	Apart wachtwoord/cookie voor de Abacus-pagina
`/api/kosten-tracking`	Maandelijkse kostenmetingen ophalen/afsluiten (los schrijfwachtwoord)

Webhooks

Route	Doel
`/api/webhooks/calendly`	Ontvangt boekingsevents (HMAC-signature + timestamp-verificatie)
`/api/webhooks/mollie`	Ontvangt Mollie-betaalmeldingen (alleen een `id`, de betaling wordt altijd zelf bij Mollie opgehaald, idempotent via `verwerkt_at`). Actief zodra `MOLLIE_API_KEY` is gezet
`/api/webhooks/resend`	Resend-events voor de blogmails. `email.bounced` (alleen permanent) en `email.complained`: meldt het adres direct af. `email.opened` en `email.clicked`: opgeslagen per bezorging (`lib/blogEngagement.ts`, kolommen `opened_count` / `clicked_count` e.d. op `arnobot_blog_deliveries`, SQL `docs/sql/2026-10-10-blog-engagement.sql`), voor de lijst "wie doet wat" in de stats. Alleen actief als open- en kliktracking voor `mail.arno.bot` in Resend aanstaat. Signature-verificatie via `RESEND_WEBHOOK_SECRET`; zonder secret doet de route niets (503)
`/api/webhooks/github-pr`	Stuurt een Telegram-melding bij een nieuw geopende PR op de repo (X-Hub-Signature-256-verificatie). PR's van de documentatie-versheidsroutine (titel begint met "Documentatie-versheidscheck") worden bewust overgeslagen, die worden in een Claude Code-sessie afgehandeld

Infrastructuur

Route	Doel
`/api/version`	Build-id t.b.v. cache-busting/versiecheck
`/api/auth-mode`	Leest of LinkedIn-loginfallback aan staat
`/api/bot/instatus`	Proxy naar Instatus-API voor de statuspagina
`/api/csp-report`	Ontvangt CSP-schendingen, meldt via Telegram
`/api/track-pageview`	Anonieme pageview-tracking marketingpagina's
`/api/track-cta-click`	Anonieme CTA-klik-tracking vóór accountaanmaak

Cron jobs

Alle crons vereisen de `Authorization: Bearer {CRON_SECRET}` header. Vercel stuurt deze automatisch. Handmatig aanroepen kan via de admin emailpagina of met een directe HTTP-call met de header.

Pad	Schema	Doel
`/api/cron/blog`	Elke 15 minuten	Blog: ingeplande posts publiceren, wachtrij vullen voor posts met "verstuur naar abonnees", wachtende blogmails versturen binnen het dagbudget (`BLOG_DAILY_MAIL_BUDGET` , standaard 50 per UTC-dag, rest van de Resend-daglimiet blijft voor betalings- en trialmails). Redis-slot tegen gelijktijdige runs
`/api/cron/trial-emails`	Dagelijks 04:05	Lifecycle e-mails: dag1, dag4, dag14, dag25, first_conversation, first_coaching
`/api/cron/inactivity-nudge`	Dagelijks 03:00	Inactiviteitsmails: 7d (gepersonaliseerd), 21d, 45d, 60d
`/api/cron/sessies-afsluiten`	Elk uur (:40)	Rondt gesprekken af die 12 uur stil liggen en geen of een achterlopende samenvatting hebben (venster 36 uur, max 12 per run). Selectie via SQL-functie `sessies_zonder_actuele_synthese` , synthese via `/api/bot/session-end` met CRON_SECRET. Sessie die 3 keer mislukt: Telegram-melding
`/api/cron/weekly-activity`	Zaterdag 04:00	Wekelijks activiteitsrapport (actieve gebruikers afgelopen 7 dagen)
`/api/cron/productvragen`	Dagelijks 06:30 UTC	Telegram-overzicht van vragen over het gebruik van ArnoBot zelf (Haiku kiest ze uit de laatste 24 uur, zonder testaccounts). Geen bericht als er niets is
`/api/cron/uitdaging-herinnering`	Dagelijks 03:10	Herinnering aan de laatste sessie-uitdaging op dag 1/3/7 (Ebbinghaus)
`/api/cron/weekly-top-users`	Zaterdag 04:05	Top 10 actieve gebruikers
`/api/cron/auto-analyse`	Dagelijks 04:05	Analyse aanmaken (`/bot/analyses`) bij 5+ nieuwe gesprekken
`/api/bot/backfill-embeddings`	Dagelijks 04:05	Embeddings aanvullen voor zoekfunctie
`/api/cron/refresh-openers`	1e vd maand 04:05	Gespreksopeners vernieuwen met verse AI-output. Analyseert de 300 meest recente gesprekken + 50 meest recente analyses (over alle gebruikers samen, aantal-gebaseerd, geen datumvenster)
`/api/cron/model-check`	1e vd maand 04:05	Modelkwaliteitscheck: live web_search + vergelijking met CLAUDE.md-inventaris
`/api/cron/competitie`	1e vd maand 04:05	Competitierapport (meest actieve gebruikers)
`/api/cron/data-cleanup`	1e vd maand 04:05	Verwijderde gesprekken opschonen, inactieve users flaggen
`/api/cron/milestone-check`	1e vd maand 04:05	Alert als 50+ actieve gebruikers bereikt (Pro-upgrade trigger)
`/api/cron/update-handover`	1e vd maand 04:10	Overdrachtsdocumenten bijwerken (dit bestand)
`/api/cron/meta-analyse`	1e vd maand 04:15	Geautomatiseerde zelfbeoordeling + expertpanel + JOUW ANALYSE
`/api/cron/patroon-samenvatting`	1e vd maand 04:20	Terugkerende namen/thema's uit `arnobot_memory_entities` als e-mail

Pad	Schema	Doel
`/api/cron/rss-ingest`	Zaterdag 00:00	RSS-feeds inladen voor kennisbank-contentverrijking
`/api/cron/meta-analyse-reminder`	27e vd maand 08:00	Herinnering om panel-input in te vullen vóór de meta-analyse-run
`/api/cron/golf1-evaluatie-herinnering`	16 september (eenmalig, jaar-guard)	Herinnering om systeemprompt-golf-1 te evalueren
`/api/cron/team-1on1-ritme`	Dagelijks 03:20	1:1-cadans-notificatie/escalatieflow: belletje bij 2+ weken geen 1:1, mail 1 na 48u ongelezen, mail 2 na 5 dagen zonder oplossing

Niet-crons ter verduidelijking: `/api/track-pageview` en `/api/track-cta-click` zijn geen crons maar event-routes die live vanuit marketingpagina's worden aangeroepen; staan daarom niet in `vercel.json`'s crons-array.

Online betalen (Mollie)

Zie `docs/MOLLIE_PLAN.md` voor het volledige plan, de besluiten en de livegang-checklist. Code in `lib/billing/` (client, prijzen en btw, perioden, verwerking, opzeggen, mails), routes `/api/bot/checkout`, `/api/bot/billing`, `/api/bot/billing/verleng`, `/api/webhooks/mollie`, `/api/cron/billing` (dagelijks 05:00 UTC: gemiste webhooks inhalen, ontbrekende abonnementen herstellen, opzeggingen stopzetten, verlengherinneringen, verlopen abonnementen afsluiten) en `/api/admin/refund`. Toegang loopt via `approved_users.expires_at` (einde betaalde periode plus 3 dagen respijt), `proxy.ts` is ongewijzigd. Tabellen: `arnobot_billing_customers`, `arnobot_subscriptions`, `arnobot_payments` (migratie: `docs/sql/2026-10-10-mollie-billing.sql`).

Database-tabellen

De database draait op Supabase (PostgreSQL). Elke query op gebruikersdata vereist altijd een `.eq('user_id', userId)` filter om IDOR te voorkomen. **RLS staat aan op alle tabellen** (zie sectie Beveiliging).

Kerntabellen (uitgebreid gedocumenteerd)

`approved_users`

Centrale gebruikerstabel. Elk account staat hier.

Kolom	Type	Inhoud
`user_id`	text (PK)	Clerk user ID (`user_xxx`) of `pending_xxx` bij e-mailaanmelding
`email`	text	E-mailadres
`voornaam`	text	Voornaam
`achternaam`	text	Achternaam
`is_active`	bool	Of het account actief is
`trial_start`	timestamptz	Startdatum trial (30 dagen gratis)
`paid_at`	timestamptz	Datum van betaling (maandelijks abonnement)
`expires_at`	timestamptz	Verloopdatum abonnement
`welcome_seen`	bool	Legacy, niet meer gebruikt (welkomspagina verwijderd)
`onboarding_done`	bool	Intake ingevuld?
`nudge_opt_out`	bool	Afgemeld voor marketingmails?
`referral_code`	text	Eigen referralcode
`linkedin`	text	LinkedIn-profiellink
`tier` / `plan`	text	`free` , `trial` , `paid` , `team` / Basic, Pro, Team
`command_manager`	bool	Recht om een team aan te maken

`arnobot_rds_logs`

Alle ruwe gespreksberichten. Elke regel = één berichtblokje (`user_id` , `role` , `content` , `session_id` , `created_at`).

`arnobot_blog_sessions`

Gesprekssessies na afsluiting, met synthese.

Kolom	Inhoud
`user_id`	Clerk user ID
`title`	AI-gegenereerde sessietitel
`summary`	Samenvatting van het gesprek
`feiten`	Kernpunten (bullets)
`uitdaging`	Actie/uitdaging voor de gebruiker
`actie_status`	`'ja'` / `'deels'` / `'nee'` / `null`. Zolang `null`, telt de sessie mee als "open actie"
`actie_klik_ms`	Milliseconden tussen tonen popup en klik (detecteert reflexief "ja"-klikken)
`actie_elaboratie`	Optionele toelichting bij "JA, GEDAAN"
`embedding`	Vector (voyage-multilingual-2) van title+summary+feiten, via de gedeelde `embedSessionText()` in `lib/rag.ts`. Doorzoekbaar via Supabase-functie `match_sessions` (user-gescoped, filtert `deleted_at`)
`deleted_at`	Soft delete timestamp. Schrijvers roepen ook `pruneEntitiesForDeletedSessions()` aan
`onderwerp`	Neutrale titel van waar het gesprek over ging (zonder uitkomst of status), gezet door `lib/memoryLabels.ts` bij opslaan en achteraf via de labelmodus van `session-end`. Dit is wat oude herinneringen in de chatprompt worden
`feiten_blijvend`	Alleen de feiten die over de gebruiker zelf of zijn eigen bedrijf gaan en jaren geldig blijven. Leeg = geen of nog niet gelabeld. Oude herinneringen (meer dan 6 weken) komen alleen hiermee en met `onderwerp` de chatprompt in, nooit met `summary` of `feiten`
`mail_verzoek`	`true` als het gesprek vooral ging om een mail of bericht aan een klant of prospect laten schrijven (`lib/mailPatroon.ts`, bepaald bij opslaan en achteraf via de mailverzoek-modus van `session-end`). `null` = nog niet bepaald. Vanaf 3 recente gesprekken met `true` zegt de chat het één keer, vanaf 5 nemen `coaching-analyse` en `coaching` het mee

`arnobot_memory_entities`

Patroongeheugen over sessies heen: namen, bedrijven en terugkerende thema's. Schrijvers via `extractAndStoreEntities()` in `lib/memoryEntities.ts`, lezer `findRecurringEntitiesInQuestion()` in `chat/route.ts`.

`arnobot_sparring_sessions`

Sales-sparringsessie-log: persona, weerstand, debrief, message_count, favoriet, transcript.

`arnobot_uitdaging_reminders_log`

Voorkomt dubbele herinneringsmails: één rij per verstuurde herinnering (`session_id` + `interval_dagen`, `UNIQUE`).

`arnobot_analyses`

Analyses van `/bot/analyses` (voorheen "BIEB"). Elke analyse dekt de afgelopen gesprekken (`user_id`, `analyse_text`, `created_at`). De kolommen `aanvulling_context`, `aanvulling_tekst` en `aanvulling_at` (migratie `docs/sql/2026-10-22-analyse-aanvulling.sql`) worden sinds 2026-10-24 niet meer gebruikt: de aanvulling-functie is verwijderd. De kolommen staan nog in de database.

`arnobot_admin_analyses`

Eén rij per gebruiker (upsert op `target_user_id`), de admin-briefing van `/bot/admin/analyse`. Nooit zichtbaar voor de gebruiker zelf, alleen voor Arno. `generated_count` telt hoe vaak de briefing (opnieuw) gegenereerd is.

`arnobot_coaching`

Meest recente coachingprofiel per gebruiker (upsert, niet append): scores + diagnoses op mindset, systeem, actie, plus voortgangstekst.

`arnobot_coaching_history`

Insert-only geschiedenis van eerdere coachingrapporten (naast `arnobot_coaching`, dat 1 rij per gebruiker blijft).

`arnobot_coaching_scores`

Historische coachingscores voor trendanalyse.

`arnobot_1on1_log`

Opgeslagen 1:1-gespreksnotities door managers (`manager_id`, `member_id`, `aandachtspunt`, scores, `notitie`).

`arnobot_blog_profiles`

Salescontext per gebruiker (bedrijf, sector, doelgroep, etc.).

`arnobot_teams`

Teamrecords: naam, `manager_id`, `invite_code`, niveau, domain-based auto-join, `min_interval_dagen`.

`arnobot_team_members`

Koppeling gebruiker aan team (`user_id`, `team_id`, `role`: manager/member).

`arnobot_team_analyses`

Team-level Spotlight-analyses (max 5 meest recente per team).

`arnobot_team_notifications`

Notificatie-inbox voor managers (bijv. "analyse gedeeld", "coaching gegenereerd", "teamlid 2+ weken geen 1:1" via `lage_1on1_cadans`, zie `app/api/cron/team-1on1-ritme/route.ts`). Geen aparte trackingtabel voor de bijbehorende escalatiemails: mail-1/mail-2-dedup en -tijdstippen staan in Redis, niet in Supabase.

`arnobot_shared_analyses`

Bijhouden welke analyses een teamlid met de manager/het team gedeeld heeft.

`arnobot_salesbaas_coaching`

Meest recente Strategy People Execution-synthese van de teambaas zelf (upsert, 1 rij per gebruiker), voor de zelfcoaching-module (`/api/bot/team/zelfcoaching`).

`arnobot_salesbaas_coaching_history`

Insert-only geschiedenis van eerdere zelfcoaching-synthesen (naast `arnobot_salesbaas_coaching`), voedt "Jouw leiderschapsreis" (mijlpalen met score + voortgangszin).

`arnobot_command_requests`

Team-tier-aanvragen via het publieke `/team`-leadformulier (bedrijfsnaam, KVK-nummer, user_id).

`arnobot_referrals`

Referraltracking: wie heeft wie uitgenodigd.

`arnobot_shared_sessions`

Publieke share-tokens voor individuele gesprekken (`/gesprek/[token]`).

`arnobot_offtopic_flags`

Vlaggen off-topic/ongepaste berichten per gebruiker; bij herhaling geforceerde uitlog.

`arnobot_events`

Generiek event-log voor productanalyse (bijv. `qa_page_view`, `coaching_gesprek_click`).

`arnobot_pageviews` / `arnobot_cta_clicks`

Anonieme pageview- en CTA-klik-tracking voor marketingpagina's (eigen tracking, naast PostHog).

`arnobot_idee_analyses`

Opgeslagen AI-blogideeën-analyses (`/api/admin/blogs-analyse`).

`arnobot_meta_analyses` / `arnobot_meta_input`

Meta-analyse-rapporten (zelfbeoordeling + expertpanel + JOUW ANALYSE) resp. Arno's ingevoerde paneltekst.

`arnobot_kb_excluded_urls` / `arnobot_meta`

Kennisbank-URL-blocklist resp. generieke key/value-metadata (o.a. `last_embed_run`, `last_rss_run`).

`blog_chunks`

RAG-kennisbank-vectorstore (`content`, `context`, `url`, `embedding`), embed-model `voyage-3-large`.

`arnobot_elevenlabs_usage`

Per-gebruiker character-count-verbruik voor ElevenLabs TTS (quota + kostenbewaking).

`arnobot_blog_posts` / `arnobot_blog_subscribers` / `arnobot_blog_deliveries`

De publieke blog (SQL: `docs/sql/2026-10-10-blog.sql`, RLS aan zonder policies, alleen service-role). **Posts:** `slug` (uniek), `title`, `summary`, `body_md` (Markdown), `cover_image_url`, `tags` (array, genormaliseerd, GIN-index), `status` (`draft` / `scheduled` / `published`), `publish_at`, `published_at`, `notify_subscribers`, `notified_at` (eenmalig versturen). **Abonnees:** `email` (unieke index op `lower(email)`), `status` (`pending` / `confirmed` / `unsubscribed`), `topics` (ongebruikt sinds 10 oktober: abonneren is altijd op alle posts, de kolom is niet meer in gebruik), `voornaam` (verplicht bij nieuwe aanmeldingen, strikte allowlist van tekens want de waarde komt ongeescaped in de mail-HTML, voor de aanhef "Hey, {voornaam}."; SQL `docs/sql/2026-10-10-blog-voornaam.sql`), `confirm_token`, `unsubscribe_token`, geen IP-opslag, de bevestigingsklik (`confirmed_at`) is het toestemmingsbewijs. **Bezorgingen:** een rij per post per abonnee (`unique(post_id, subscriber_id)`), `queued` / `sent` / `failed`, `attempts`, `resend_id`. Dit maakt versturen idempotent en laat het dagbudget de wachtrij over dagen verdelen. Afbeeldingen in de publieke Storage-bucket `blog-images`. Publieke pagina's lezen via een gecachete Supabase-client (Next fetch-cache, tag `blog`, direct ververst via `revalidateBlog()` na elke adminwijziging), omdat de root layout `headers()` leest en dus elke pagina per verzoek rendert.

`arnobot_csp_violations`

CSP-schendingsrapporten (`document_uri`, `violated_directive`, `blocked_uri`).

`arnobot_email_log`

Bijhouden welke trial-lifecycle-e-mails al verstuurd zijn per gebruiker.

`arnobot_settings`

Generieke boolean feature-flag key/value-store.

`arnobot_kosten_tracking`

Maandelijkse kosten/omzet-tracking (Abacus Trackrecord-tab).

`arno_blog_widget_logs` / `arno_blog_widget_blocked`

Log resp. IP-blocklist voor de anonieme publieke blog-chatwidget.

`inactivity_nudge_log`

Bijhouden welke inactiviteitsmails (dag21/dag45/dag60) al verstuurd zijn per gebruiker.

Authenticatie en autorisatie

Gebruikersauthenticatie: Clerk (`@clerk/nextjs`). Gebruikers loggen in via e-mail/wachtwoord of LinkedIn OAuth.

Toegangslogica (proxy.ts):

1. Scanner-requests (`.env`, `wp-admin`, etc.) → direct 404
2. Admin-routes (`/bot/admin/*`) → cookie-gebaseerd (`arnobot_admin`)

3. Bot-routes (`/bot/*`) → Clerk auth vereist + `approved_users` check
4. Toegangsstatus op basis van: `paid_at` aanwezig → altijd toegang; anders `expires_at` in toekomst; anders `trial_start` + 30 dagen niet verstreken
5. `onboarding_done` niet waar → redirect `/bot/profiel`

Losse cookie-gates buiten `/bot`: `/abacus/*` via `arnobot_kosten` (`ARNOBOT_KOSTEN_KEY`), `/agents/*` via `arnobot_sd_verdien` (`SD_VERDIEN_PASSWORD`, admin-key werkt ook). Geen Clerk-auth, zelfde patroon als de admin-cookie.

Sales-development-attributie (proxy.ts): `/aanmelden?sd=<token>` zet een cookie (`arnobot_sd`, `app/aanmelden/page.tsx`). Bij accountaanmaak matcht `proxy.ts` die cookie tegen de env vars `SD_TOKEN_STEFANIE` / `SD_TOKEN_ANNIEK` en zet bij een match `command_manager=true` mee in dezelfde insert. Zie `docs/SALES_DEVELOPMENT.md` voor de volledige uitleg.

Admin-authenticatie: Aparte cookie (`arnobot_admin`). Login via `/bot/admin/login` met het `ARNOBOT_ADMIN_KEY` environment variable als wachtwoord. Niet via Clerk.

Bewuste keuze, geen wijziging gepland: drie interne oppervlaktes (`arnobot_admin`, `arnobot_kosten`, `arnobot_sd_verdien`) draaien elk op een eigen wachtwoord-cookie in plaats van gecentraliseerde RBAC binnen Clerk. Dit is geen openstaand gebrek: bij het huidige aantal beheerders (Arno + een paar sales agents) voegt centrale RBAC alleen coördinatie-overhead toe zonder reëel veiligheidsvoordeel. Pas heroverwegen als het aantal beheerders/rollen wezenlijk groeit.

API-route beveiliging: Alle `/api/bot/*` routes roepen `auth()` aan (Clerk server-side). Crons controleren `Authorization: Bearer {CRON_SECRET}`.

Openstaand: `proxy.ts` gebruikt nog `createRouteMatcher()` (Clerk) voor `isProtectedBot` / `isAdminRoute`. Sinds `@clerk/nextjs` 7.5.14 is dit gedeprecate ten gunste van `auth.protect()` per route. Geen breaking change, geen aangekondigde verwijderdatum, maar wel migreren zodra opgepakt.

Beveiliging

- **Row Level Security (RLS):** aan op alle ~41 tabellen (sinds 2026-08-20, geen policies). Veilig als achtervang tegen de publieke anon-key, maar géén echte multi-tenant isolatie: de app gebruikt overal de service-role-key (die RLS altijd omzeilt), niet de Clerk-JWT-Supabase-client die wel in `lib/supabase.ts` klaarstaat maar nergens geïmporteerd wordt. Isolatie tussen gebruikers hangt daardoor volledig af van een `.eq('user_id', userId)`-filter per route, zonder database-afgedwongen vangnet — precies het risico dat de check hieronder afdekt.
- **Ontbrekende-eigenaarschapsfilter-check:** `scripts/check-missing-user-filter.mjs` (sinds 2026-08-21, niet-blokkerende CI-stap). Scant `app/api/**`, `app/bot/**` en `lib/**` op `.from()`-aanroepen op gebruikersdata-tabellen zonder `.eq()` / `.in()` op `user_id` / `manager_id` / `member_id` binnen dezelfde functie (admin/cron/login-routes zijn bewust uitgesloten, die queryen terecht gebruikersoverstijgend). Statische tekstanalyse, geen dataflow-check — bevestigde legitieme uitzonderingen staan in `KNOWN_SAFE_QUERIES` in het script zelf.
- **CSP (Content Security Policy):** Gegenereerd per request met nonce in `proxy.ts`. Blokkeert inline scripts zonder nonce. PostHog- en Sentry-verkeer lopen via same-origin proxy's (`/site-relay`,

`/monitoring`), dus geen externe host-uitzonderingen nodig in de CSP.

- **Security headers:** `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Strict-Transport-Security`, `Referrer-Policy`, `Permissions-Policy`.
- **Rate limiting:** Upstash Redis via `@upstash/ratelimit`. Actief op AI-routes en losse voice-routes.
- **Prompt injection detectie:** Regex-check op inkomende berichten in `/api/chat` voor veelgebruikte injectionpatronen (NL + EN).
- **User-filter op queries:** Elke Supabase-query op gebruikersdata vereist `.eq('user_id', userId)`. userId altijd uit Clerk `auth()`, nooit uit de request body.
- **Disposable e-mails:** `disposable-email-domains` package filtert wegwerpmail bij aanmelding.
- **CSP-rapportage:** Schendingen worden gelogd via `/api/csp-report` en `arnobot_csp_violations`.
- **Webhook-verificatie:** Calendly-webhook verifieert `Calendly-Webhook-Signature` (HMAC-SHA256, 5 minuten replay-venster).

Testen en CI

Elke push/PR naar `master` triggert `.github/workflows/security-audit.yml` (niet: iedere job blokkeert de merge, zie hieronder). Wekelijks (maandag 08:00 UTC) draait een uitgebreidere variant.

Job	Wanneer	Blokkeert?	Doel
npm audit	elke push/PR + wekelijks	nee (alleen `--audit-level=critical`)	Kritieke runtime-kwetsbaarheden
TypeScript typecheck	elke push/PR	ja (impliciet: Vercel build faalt anders ook)	`npx tsc --noEmit`
Vitest	elke push/PR	ja	Regressietests kritieke paden (streepjes-sanitizer, systeemprompt-opbouw, RAG-dedupe). Geen externe aanroepen, Supabase/Voyage gemockt
Playwright E2E (UI, gemockte AI)	elke push/PR	ja	Golden path + scenario's + a11y, `/api/chat` volledig gemockt op browserniveau
Playwright E2E (echte backend) + contracttests	alleen wekelijks	n.v.t.	Niveau-3 met echte Supabase/Upstash-keten, plus contracttests met echte Anthropic/Voyage-aanroepen (`RUN_CONTRACT_TESTS=true`)
ESLint	elke push/PR	nee	66 bestaande lint-fouten in oudere code (gemeten 2026-07-10), opruimen is een apart project
Wees-routes-check	elke push/PR	nee	`scripts/check-orphan-routes.mjs`, zie CLAUDE.md sectie 1
Ontbrekende-eigenaarschapsfilter-check	elke push/PR	nee	`scripts/check-missing-user-filter.mjs`, zie sectie Beveiliging hierboven

Lokaal draaien: `npx tsc --noEmit`, `npm test` (Vitest), `npx playwright test` (vereist E2E_CLERK_PUBLISHABLE_KEY/E2E_CLERK_SECRET_KEY van een Clerk development-instance, zie `e2e/auth.setup.ts`).

AI-modellen en routering

Route	Model	Reden (kort)	Laatste check
`app/api/chat/route.ts` (hoofdchat, streaming)	`claude-sonnet-4-6`	Sonnet 5 gaf leeg antwoord bij lange vragen. Retry-bij-leeg + max_tokens-buffer + Sentry-log bij afkapping.	2026-08-18
`app/api/chat/route.ts` (RAG-queryherschrijving/checks)	`claude-haiku-4-5-20251001`	Korte classificatie/herschrijfstappen met expliciete fallbacks.	2026-07
`app/api/chat/route.ts` (audiobijlage-transcriptie, `lib/assemblyai.ts`)	`universal-3-5-pro` (AssemblyAI)	Best scorende model op Nederlands in AssemblyAI's eigen FLEURS-benchmark (6,7% WER), inclusief sprekersherkenning. Ongedocumenteerde functie: bestaande bijlage-knop in de hoofdchat accepteert ook audio (mp3/wav/m4a, max 150MB, Pro/Team-only), transcript stroomt als tekst de bestaande hoofdchat-call in, geen aparte pagina of opslag.	2026-09-17
`app/api/bot/uitdaging/route.ts`	`claude-fable-5-1`	"Thought of the day", grammaticale kwaliteit vereist Fable. Naar Fable 5.1 (2026-09-07): drop-in, gelijke prijs, blinde A/B toonde geen regressie. Toon/drempel herzien 2026-08-29.	2026-09-07
`lib/memoryLabels.ts` (onderwerp en blijvende feiten per sessie, aangeroepen vanuit `session-end` en de labelmodus)	`claude-haiku-4-5-20251001`	Labelt een afgerond gesprek voor het sessiegeheugen: neutraal onderwerp en welke feiten blijvend zijn. Bewust streng (twijfel = niet blijvend). Mislukt het, dan blijven de kolommen leeg en valt de chat terug op alleen de titel: veilig. Gemeten 2026-10-31.	2026-10-31
`lib/mailPatroon.ts` (`herkenMailVerzoek`, aangeroepen vanuit `session-end` en de mailverzoek-modus)	`claude-sonnet-4-6`	Ja/nee per gesprek: ging het vooral om een mail of bericht aan een klant laten schrijven? Klein, alleen de vragen van de gebruiker als invoer. Sonnet en niet Haiku: Haiku had 4 van 16 valse positieven (strategievragen waarin een script terloops werd genoemd), en een vals "je gebruikt mij als tekstschrijver" naar de gebruiker is een foute bewering. Mislukt het, dan blijft `mail_verzoek` leeg en komt er geen signaal. Gemeten 2026-10-31.	2026-10-31
`app/api/bot/session-end/route.ts` (synthese/feiten/uitdaging/classificatie)	`claude-haiku-4-5-20251001`	4 parallelle batch-calls. Retry-bij-leeg per call; classificatie bewust zonder retry.	2026-08-21
`app/api/bot/coaching/route.ts` (precheck)	`claude-sonnet-5`	Alleen ja/nee-vraag, Fable overkill.	2026-07

Route	Model	Reden (kort)	Laatste check
`app/api/bot/team/zelfcoaching/route.ts` (SPE-synthese teambaas)	`claude-fable-5-1`	Belangrijkste synthese voor de teambaas, kosten geen factor. Refusal-check + retry vanaf v1. Naar Fable 5.1 (2026-09-07): drop-in, gelijke prijs.	2026-09-07
`app/api/bot/coaching/route.ts` (hoofdsynthese)	`claude-fable-5-1`	Hoogste kwaliteit voor de belangrijkste synthese. max_tokens 4000. Naar Fable 5.1 (2026-09-07): blinde A/B op echte gebruikersdata, JSON-schema intact, geen regressie.	2026-09-07
`app/api/bot/coaching/route.ts` (blog-synthese)	`claude-haiku-4-5-20251001`	Korte label per blog.	2026-07
`app/api/bot/coaching-analyse/route.ts` (Analyses-pagina)	`claude-sonnet-4-6`	Gemigreerd van Sonnet 5 (stil leeg antwoord). Retry + zichtbare foutmelding.	2026-07
`app/api/bot/team/spotlight/route.ts` (team spotlight)	`claude-sonnet-4-6`	Cruciale boodschap voor manager. Krijgt thema-geschiedenis + 21-dagen-signaal als context.	2026-08-21
`app/api/bot/team/1on1/route.ts` (1:1 agenda)	`claude-haiku-4-5-20251001`	Sonnet 5 kapte output af. Haiku geen thinking, sneller, volstaat voor gestructureerde agenda.	2026-07
`app/api/sparring/debrief/route.ts`	`claude-sonnet-4-6`	Stond op Sonnet 5, lege debrief bij lange transcripten. Retry + fallbacktekst.	2026-07
`app/api/sparring/chat/route.ts` (live sparring)	`claude-sonnet-4-6`	try/catch + Sentry, expliciete 502 i.p.v. nepantwoord.	2026-07
`app/api/sparring/open/route.ts` (opening sparring)	`claude-sonnet-4-6`	Zelfde bug/fix als sparring/chat.	2026-07
`app/api/cron/auto-analyse/route.ts`	`claude-sonnet-4-6`	Batch over max 20 gesprekken/gebruiker. Bij aanhoudend leeg: gebruiker overslaan.	2026-07
`lib/rag.ts` (queryherschrijving RAG)	`claude-haiku-4-5-20251001`	3 zoekzinnen per vraag, eenvoudige herschrijftaak.	2026-07
`lib/rag.ts` (embedding, kennisbank RAG)	`voyage-3-large`	Legacy. NIET losstaand upgraden: breekt de kennisbank (vooraf ge-embed). voyage-4-large onderzocht 2026-09-02, geen kwaliteitswinst, traject geparkeerd (`docs/VOYAGE_REEMBED_PLAN.md`).	2026-09-02
`lib/rag.ts` (rerank, kennisbank RAG)	`rerank-2.5`	Geüpgraded van `rerank-2` (legacy), strikt beter, zelfde prijs.	2026-07
`lib/rag.ts` (`embedSessionText`, sessie-geheugen)	`voyage-multilingual-2`	Model-mix-bug gefixt 2026-08-12, alle schrijvers geconsolideerd. Deprecated, NIET losstaand upgraden. voyage-4-migratie geparkeerd, zie kennisbank-rij hierboven.	2026-09-02

Route	Model	Reden (kort)	Laatste check
`app/api/bot/coaching-precheck/route.ts`	`claude-sonnet-4-6`	Losse ja/nee-check, expliciete fallback (`'nee'`).	2026-07
`app/api/bot/verfijn/route.ts`	`claude-sonnet-4-6`	Herschrijft een gebruikersvraag, fallback = originele vraag, max 2000 tekens.	2026-07
`app/api/bot/search-linkedin-profile/route.ts`	`claude-sonnet-4-6` (+ web_search)	Opzoektaak met expliciete "niet gevonden"-afhandeling.	2026-07
`app/api/bot/sessions/route.ts`	`claude-haiku-4-5-20251001`	Nog niet beoordeeld op leeg-antwoord-risico.	2026-07
`app/api/bot/sessions/search/route.ts`	`claude-haiku-4-5-20251001`	JSON-fallback (`[]`) bij parse-fout.	2026-07
`lib/memoryEntities.ts` (`extractAndStoreEntities`)	`claude-haiku-4-5-20251001`	Extraheert namen/bedrijven/thema's per sessie. JSON-fallback, faalt stil (laag risico).	2026-08-12
`lib/groeibalansServer.ts` (`recomputeGroeibalans` , Gebruiksbalans-classificatie + persoonlijk advies en sparscenario)	`claude-sonnet-4-6`	Sinds 2026-10-05 ook een persoonlijke zin uit de eigen historie (thema's, laatste sparsessie, coaching, teamthema) plus voorgesteld sparscenario, daarom Sonnet i.p.v. Haiku (taalkwaliteit). Fail-open, advies valt terug op de vaste kadertekst. Aangeroepen vanuit session-end en sparring/debrief.	2026-10-05
`app/api/cron/refresh-openers/route.ts`	`claude-sonnet-4-6`	Expliciete check op geldige JSON-structuur.	2026-07
`app/api/cron/rss-ingest/route.ts`	`claude-haiku-4-5-20251001`	Expliciete fallback-tekst.	2026-07
`app/api/cron/feitencontrole/route.ts`	`claude-sonnet-4-6`	Dagelijks 06:45 UTC. Voorselectie op telwoorden in antwoorden die niet in het gesprek staan (`lib/feitenControle.ts`), daarna een oordeel van Sonnet over alleen die kandidaten, Telegram-melding als een antwoord een feit van de gebruiker verkeerd terugspeelt ("vier bronnen" terwijl er twee genoemd waren). Draait op opgeslagen antwoorden, dus zonder vertraging in de chat. Sonnet en niet Haiku: een valse melding kost Arno tijd, en Haiku had bij het mailpatroon te veel valse positieven. Besloten 2026-10-31 (verworpen: eerst controleren dan tonen, want de chat streamt en dat maakt elk antwoord trager). Gemeten: bij Thijs' briefing 0 echte telfouten in 60 runs, dus zeldzaam.	2026-10-31
`app/api/cron/productvragen/route.ts`	`claude-haiku-4-5-20251001`	Dagelijks 06:30 UTC. Kiest uit de vragen van de laatste 24 uur (zonder	2026-10-21

Route	Model	Reden (kort)	Laatste check
		testaccounts) welke over het gebruik van ArnoBot zelf gaan en meldt die in één Telegram-bericht, alleen als er iets is. Retry-bij-leeg, bij aanhoudend ongeldig antwoord een cron-foutmelding i.p.v. stilte. Besloten 2026-10-21 als losse cron (verworpen: controle per bericht in `chat/route.ts`, raakt de chat).	
`app/api/cron/inactivity-nudge/route.ts`	`claude-haiku-4-5-20251001`	Valt terug op generieke e-mailtemplate bij fout.	2026-07
`app/api/cron/model-check/route.ts` (adviesgeneratie, e-mail only)	`claude-sonnet-4-6` (+ web_search)	Haalt de modeltabel live uit CLAUDE.md via GitHub API, echte web_search naar pricingpagina's. Faalt hard bij ophaalfout.	2026-08-12
`app/api/admin/feedback-analyse/route.ts`	`claude-haiku-4-5-20251001`	Nog geen expliciete leeg-check.	2026-07
`scripts/embed-chunks.mjs` (contextgeneratie per chunk)	`claude-haiku-4-5-20251001`	Offline script dat de kennisbank vult. try/catch-fallback.	2026-07
`scripts/translate-knowledge-base.mjs`	`claude-opus-5`	Enige Opus-gebruik. `tool_choice` forceert tool_use. Opus 5 kost gelijk aan 4.8, presteert beter.	2026-07
`app/api/admin/blogs-analyse/route.ts`	`claude-sonnet-4-6`	Redactionele briefing. Retry-bij-leeg + expliciete foutrespons.	2026-07
`lib/metaAnalyse.ts` (zelfbeoordeling + expertpanel)	`claude-fable-5-1`	Geüpgraded van Sonnet 4.6 (2026-08-18), essentieel onderdeel, kosten geen factor. Refusal-check, hogere max_tokens, gesprekken schalen met periode. Sinds 2026-09-02 één gedeelde implementatie voor `cron/meta-analyse` (days=30, e-mail) én `admin/meta-analyse` (periodekeuze, JSON). Naar Fable 5.1 (2026-09-07): drop-in, gelijke prijs.	2026-09-07
`lib/metaAnalyse.ts` (jouw analyse)	`claude-fable-5-1`	Verwerkt Arno's eigen input puntsgewijs. Refusal-check + `jouwAnalyseFailed` na stille-faal-bug. Zelfde gedeelde module. Naar Fable 5.1 (2026-09-07).	2026-09-07
`app/api/admin/test-email/route.ts`	`claude-haiku-4-5-20251001`	Admin-testtool, geen gebruikersgerichte output.	2026-07
`app/api/admin/analyse/route.ts` (briefing per gebruiker)	`claude-fable-5-1`	ANALYSE-tab in admin, vervangt Arno's handmatige uitzoekwerk. Refusal-check + retry + max_tokens-verdubbeling vanaf v1. Naar Fable 5.1 (2026-09-07).	2026-09-07

Route	Model	Reden (kort)	Laatste check
`app/api/admin/analyse-chat/route.ts` (doorvragen op de briefing)	`claude-fable-5-1`	Zelfde databundel. Bewust niet opgeslagen. Naar Fable 5.1 (2026-09-07).	2026-09-07
`app/api/transcribe/route.ts`	`gpt-4o-transcribe` (OpenAI, rauwe fetch)	Spraak-naar-tekst voor voice-input, `stream=true` (SSE). Gemigreerd van `whisper-1` (deprecated).	2026-09-29
`app/api/chat-voice/route.ts` (ArnoBot Voice, echte gebruikers)	`claude-sonnet-4-6`	Korte voice-systeeminstructie (`buildVoiceSystemPrompt`), niet-streamend. Eigen rate-limiter (30/uur).	2026-07
`app/api/tts-voice/route.ts` (ArnoBot Voice, echte gebruikers)	`eleven_flash_v2_5` (ElevenLabs, rauwe fetch)	Server haalt op via ElevenLabs' streamende `/stream/with-timestamps`-endpoint (`lib/voice.ts`, `fetchElevenLabsSpeechWithAlignment`) en voegt de NDJSON-chunks (audio + cumulatieve karakter-alignment) samen tot één JSON-respons voor de client, voor de karaoke-highlight/meescroll-weergave in `SparClient.tsx`. Eerst de niet-streamende `/with-timestamps`-variant geweest, bleek bij meting ~3,5x trager (2,3s vs 0,65s), teruggedraaid na Arno's klacht over trage voice-out. Client wacht nog wel op complete audio vóór afspelen (bewust geen MediaSource-streaming, onbetrouwbaar op mobiele Safari). Verbruik gelogd. Eigen rate-limiter (60/uur).	2026-09-29
`app/api/admin/voice-test/chat/route.ts` (admin-only testfase)	`claude-sonnet-4-6`	Interne testroute, deelt `getVoiceAnswer()`.	2026-07
`app/api/admin/voice-test/tts/route.ts` (admin-only testfase)	`eleven_flash_v2_5` (ElevenLabs, rauwe fetch)	Interne testroute, deelt `fetchElevenLabsSpeech()`.	2026-07

Beslissingsvolgorde: kwaliteit eerst, kosten tweede. Een goedkoper model wordt alleen gekozen als de kwaliteit aantoonbaar gelijkwaardig is voor die specifieke taak.

Openstaand actiepunt: Hercheck of Sonnet 5 de thinking-mode-truncatie heeft opgelost voor de hoofdchat. Sonnet 5's introductieprijs ($2/$10 per miljoen tokens) is sinds 11 augustus 2026 permanent gemaakt, dus structureel goedkoper dan Sonnet 4.6 — maakt de hercheck aantrekkelijker. Test eerst op staging. Livegang-datum is uitgesteld (was 1 augustus 2026, nu vermoedelijk september/oktober 2026); check bij Arno de actuele datum vóór dit oppakken, ga niet af op een datum die eerder in CLAUDE.md heeft gestaan.

Volledige inventaris + toelichting per beslissing: zie CLAUDE.md, sectie "Model-inventaris".

Package-versies

Package	Versie
next	^16.4.3
react	^19.2.8
@anthropic-ai/sdk	^0.115.0
@clerk/nextjs	^7.9.10
@supabase/supabase-js	^2.115.0
resend	^6.32.1
@upstash/ratelimit	^2.0.8
@upstash/redis	^1.38.3
@sentry/nextjs	^10.78.0
posthog-js	^1.430.3
@react-pdf/renderer	^4.3.3
jspdf	^4.2.0
typescript	^6

Nieuw sinds vorige versie van dit document: `@sentry/nextjs`, `posthog-js`, `styled-components`, `mammoth`, `lucide-react`, `@capacitor/*` (Android-wrapper, in ontwikkeling). **Verwijderd:** `sanity`, `next-sanity`, `@portabletext/react` (2026-08-01, dode code na CMS-migratie).

Externe diensten

Voor elk van deze diensten heb je toegang nodig om de app te runnen. Zie BUSINESS_HANDOVER.md voor waar de inloggegevens staan.

Vercel

Doel: Hosting, serverless functions, cron jobs, environment variables. **Dashboard:** https://vercel.com/arnoceo-ops/arnobot **Kritieke acties:**

- Environment variables beheren (Settings > Environment Variables)
- Deployments bekijken en terugdraaien (Deployments)
- Vercel Logs bekijken voor errors en cron output (Logs)
- Cron jobs monitoren (Settings > Crons)

Environment variables die vereist zijn:

- `NEXT_PUBLIC_SUPABASE_URL` / `SUPABASE_SERVICE_ROLE_KEY` / `NEXT_PUBLIC_SUPABASE_ANON_KEY` — Supabase
- `NEXT_PUBLIC_CLERK_PUBLISHABLE_KEY` / `CLERK_SECRET_KEY` — Clerk
- `ANTHROPIC_API_KEY` — Anthropic API key
- `VOYAGE_API_KEY` (+ optioneel `VOYAGE_BASE_URL`) — Voyage AI (embeddings/rerank)

- `OPENAI_API_KEY` — OpenAI Whisper (transcriptie)
- `ELEVENLABS_API_KEY` + `ELEVENLABS_VOICE_ID` — ElevenLabs (voice TTS)
- `NEXT_PUBLIC_POSTHOG_KEY` — PostHog
- `RESEND_API_KEY` — Resend
- `RESEND_WEBHOOK_SECRET` — signing secret van de Resend-webhook voor bounces en klachten (blog)
- `BLOG_MAIL_FROM` (optioneel, standaard `ArnoBot <blog@mail.arno.bot>`) en `BLOG_DAILY_MAIL_BUDGET` (optioneel, standaard 50) — blogmails
- `UPSTASH_REDIS_REST_URL` + `UPSTASH_REDIS_REST_TOKEN` — Upstash Redis
- `CRON_SECRET` — Geheime token voor cron autorisatie
- `ARNOBOT_ADMIN_KEY` — Admin paneel wachtwoord
- `ARNOBOT_KOSTEN_KEY` + `ARNOBOT_KOSTEN_WRITE_KEY` — Abacus-toegang
- `SD_VERDIEN_PASSWORD` — Agents-portaal wachtwoord
- `SD_TOKEN_STEFANIE` / `SD_TOKEN_ANNIEK` — sales-development-attributielinks
- `CALENDLY_WEBHOOK_SIGNING_KEY` — Calendly-webhookverificatie
- `INSTATUS_API_KEY` — statuspagina-data
- `ARNOBOT_OWNER_USER_ID` — Clerk user ID van Arno (voor admin-functies)
- `GITHUB_TOKEN` — GitHub PAT voor de update-handover cron
- `TELEGRAM_BOT_TOKEN` + `TELEGRAM_CHAT_ID` — Telegram notificaties

Supabase

Doel: PostgreSQL database, alle gebruikersdata. **Dashboard:** https://supabase.com/dashboard (project: wxrsmmzqbmoeackirsxc — arno.bot) **Kritieke acties:**

- SQL Editor: directe queries uitvoeren
- Table Editor: data bekijken en bewerken
- Gebruiker toevoegen: INSERT in `approved_users`
- Gebruiker deactiveren: `UPDATE approved_users SET is_active = false WHERE user_id = '...'`
- API-keys bekijken (Settings > API)
- Database backups (Settings > Backups) — automatisch dagelijks op Pro plan (7 dagen bewaartermijn)
- RLS-status controleren: Database > Tables, kolom RLS mag nooit "Disabled" tonen

Status: Pro-plan actief. RLS aan op alle tabellen (geen policies, veilig zolang uitsluitend de service-role-key gebruikt wordt). PITR (Point-In-Time Recovery) nog niet aangezet, gepland bij 150 actieve gebruikers, zie CLAUDE.md.

Clerk

Doel: Authenticatie, gebruikersbeheer, LinkedIn OAuth. **Dashboard:** https://dashboard.clerk.com **Kritieke acties:**

- Gebruikers zoeken en bekijken (Users)
- User ID opzoeken voor Supabase-queries

- OAuth providers beheren (LinkedIn)
- Clerk custom domain: `clerk.arno.bot` (via DNS)

Let op: Zorg dat je niet per ongeluk een production-instance verwisselt met een development-instance. **Deadline 18 januari 2027:** Clerk stopt met oude CBC-mode TLS-cipher suites op custom domains, waarschijnlijk geen actie nodig voor deze stack maar controleren vóór de deadline.

Anthropic

Doel: Claude AI API. **Dashboard:** https://console.anthropic.com **Kritieke acties:**

- API-key beheren (API Keys)
- Gebruik en kosten bekijken (Usage)
- Workspaces en rate limits (Organization)

Harde deadline: de huidige API-keys (arnobot + salescanvas-app) verlopen op 6 januari 2027, door Anthropic afgedwongen. Ruim van tevoren nieuwe keys aanmaken en uitrollen.

VoyageAI

Doel: Embedding + rerank API voor semantisch zoeken in de kennisbank (`blog_chunks`) en gesprekken (`arnobot_blog_sessions`). **Dashboard:** https://dash.voyageai.com **Integratie:** rauwe fetch in `lib/rag.ts`, geen SDK. **Kritieke acties:** API-key beheren, gebruik bekijken.

OpenAI

Doel: Whisper (`whisper-1`) spraak-naar-tekst voor voice-input. **Dashboard:** https://platform.openai.com **Integratie:** rauwe fetch in `app/api/transcribe/route.ts`, geen SDK.

ElevenLabs

Doel: Tekst-naar-spraak voor ArnoBot Voice (premium-feature, `plan` premium/team). **Dashboard:** https://elevenlabs.io **Integratie:** rauwe fetch in `lib/voice.ts` (model `eleven_flash_v2_5`), geen SDK. Verbruik gelogd in `arnobot_elevenlabs_usage`. **Let op:** "Improve the models for everyone" (traint op klantdata) staat standaard AAN bij ElevenLabs — bewust uitgezet vóór livegang.

Resend

Doel: E-mail verzending. **Dashboard:** https://resend.com **Kritieke acties:**

- Verzonden e-mails bekijken (Emails)
- DKIM-status controleren (Domains > arno.bot)
- API-key beheren (API Keys)
- Bounces en errors bekijken

Verzendend adres: `ArnoBot <info@arno.bot>` (transactioneel). Blogmails gaan via het apart geverifieerde subdomein `mail.arno.bot` (`ArnoBot <blog@mail.arno.bot>`, Reply-To `hq@arno.bot`), zodat de reputatie van blogmails gescheiden blijft van betalings- en trialmails. DNS staat bij Vercel (records: DKIM-TXT en twee CNAME's `rsend.mail` en `send.mail`). Gratis tier: 100 mails per dag voor alles samen, daarom het dagbudget voor blogmails; Resend Pro bij ~50 bevestigde abonnees. **Opt-out gaat naar:** `/optout/[token]` (publieke route, geen login nodig)

Upstash

Doel: Redis voor rate limiting op AI-routes. **Dashboard:** https://console.upstash.com **Kritieke acties:** REST URL en token bekijken, gebruik monitoren

Sentry

Doel: Foutmonitoring + performance tracing. **Init:** `sentry.server.config.ts`, `sentry.edge.config.ts`. Tunnel-endpoint `app/monitoring/route.ts` (proxy naar Sentry, dodge ad-blockers). **Kritieke acties:** Errors/spans bekijken, quota controleren.

PostHog

Doel: Bezoekers- en productgebruiksanalyse (naast de eigen `arnobot_pageviews` / `arnobot_cta_clicks` / `arnobot_events`-tracking, die de bron blijft voor `/bot/admin/stats`). **Integratie:** `posthog-js`, geproxyd via `/site-relay` (same-origin, dodge ad-blockers). Bewust géén autocapture. **Scope publiek:** anonieme `capture()` op publieke componenten (`PostHogTracker.tsx`). **Scope ingelogd (`/bot`, sinds 2026-08-30):** pseudoniem. `identify()` met Clerk `user_id`, veilige person-properties via `app/api/bot/posthog-identity/route.ts`, genormaliseerde `$pageview` (geen query/IDs), event-whitelist als getypte union in `lib/posthog.ts` (`track()`). `/bot/admin` uitgesloten. Nooit gespreks-/coaching-/analyse-inhoud. `team_id` als super-property (geen betaalde group-analytics). **Session replay:** `PostHogSessionReplay.tsx`, UIT achter `SESSION_REPLAY_ENABLED` in `lib/posthog.ts`. Aan = allowlist van shell-pagina's, alle tekst + invoer gemaskeerd, geen netwerk-payloads. **Feature flags / surveys:** operationeel met de SDK-integratie, per feature in te richten. **Openstaand:** DPA opvragen, bewaartermijn instellen, replay-vlag omzetten na verificatie. Data Warehouse Stripe geblokkeerd tot betaalprovider.

Calendly

Doel: Boeking van het 1-op-1-gesprek met Arno. **Integratie:** inkomend webhook `/api/webhooks/calendly` (HMAC-geverifieerd), zet `arno_call_booked_at` op `approved_users`. **Let op:** callback-URL moet `https://www.arno.bot/api/webhooks/calendly` zijn (mét www).

Instatus

Doel: Publieke statuspagina-data (uptime/incidenten) voor `/bot/admin/status`. **Integratie:** rauwe fetch in `app/api/bot/instatus/route.ts`, geen SDK.

GitHub

Doel: Source code, CI/CD trigger voor Vercel, bron voor de `update-handover`-cron. **Repo:** https://github.com/arnoceo-ops/arnobot **Kritieke acties:** Code bekijken, branches beheren, commits terugdraaien

Telegram

Doel: Ops-notificaties (nieuwe gebruikers, cron-failures, CSP-schendingen). **Setup:** Een Telegram-bot (`TELEGRAM_BOT_TOKEN`) stuurt berichten naar een chat (`TELEGRAM_CHAT_ID`). Beheren via @BotFather.

Geen payment-provider geïntegreerd: bewust pending, zie "Bekende beperkingen" punt 11 voor het triggercriterium.

Veelvoorkomende operaties

Gebruiker handmatig toevoegen (trial)

```
INSERT INTO approved_users (user_id, email, voornaam, achternaam, is_active, trial_start)
VALUES ('pending_[willekeurige-string]', 'email@example.com', 'Voornaam', 'Achternaam', true, now());
```

De gebruiker logt in via Clerk en het pending-record wordt automatisch bijgewerkt.

Gebruiker betaald zetten

Ga naar `/bot/admin/gebruikers`, zoek de gebruiker op, of gebruik de admin payment route:

```
POST /api/admin/payment
{ "userId": "user_xxx", "months": 1 }
```

Gebruiker deactiveren

```
UPDATE approved_users SET is_active = false WHERE user_id = 'user_xxx';
```

Cron handmatig draaien

Ga naar `/bot/admin/emails` en gebruik de "STUUR TEST" knoppen voor admin crons. Of roep de route direct aan:

```
curl -H "Authorization: Bearer [CRON_SECRET]" https://arno.bot/api/cron/[naam]
```

Deployment terugdraaien

Vercel dashboard > Deployments > klik op eerdere deployment > "Promote to Production"

Error debuggen

Vercel dashboard > Logs bekijken voor errors, of Sentry-dashboard voor gestructureerde stack traces + performance-tracing.

Database query uitvoeren

Supabase dashboard > SQL Editor > schrijf je query. Let op: altijd een WHERE-clause bij schrijfoperaties.

E-mail testen

`/bot/admin/emails` — lijst met alle e-mail templates, elke met testknop.

Bekende beperkingen en openstaande punten

1. **Sonnet 5 hoofdchat:** Teruggedraaid naar Sonnet 4.6 wegens thinking-mode truncatie. Sonnet 5's prijs is inmiddels permanent verlaagd, wat een hercheck aantrekkelijker maakt — check eerst de actuele livegang-datum bij Arno, test op staging.
2. **RLS Supabase — bewust pending:** Ingeschakeld op alle ~41 tabellen (2026-08-20), maar zonder policies dus geen echte multi-tenant isolatie. De service-role-key omzeilt RLS altijd, dus scheiding tussen gebruikers hangt in de praktijk af van een `.eq('user_id', userId)`-filter per route. Sinds 2026-08-21 bewaakt `scripts/check-missing-user-filter.mjs` dit automatisch (niet-blokkerend, geen database-afgedwongen garantie). **Triggercriterium om alsnog op te pakken:** een tweede developer die routinematig gebruikersdata-routes wijzigt (het huidige risico is grotendeels beheersbaar zolang Arno alle wijzigingen zelf overziet), een compliance-eis van een enterprise-klant, of een keer dat de CI-check daadwerkelijk iets vindt dat pas laat wordt opgemerkt. Echte multi-tenant RLS met Clerk-JWT-policies (de al-aanwezige, ongebruikte client in `lib/supabase.ts` daadwerkelijk inzetten) is dan een apart traject van meerdere dagen, raakt ~40 routes.
3. **Embedding-modellen verouderd — bewust pending:** `voyage-3-large` (kennisbank) is legacy, `voyage-multilingual-2` (sessiegeheugen) is deprecated (nog geen aangekondigde einddatum). Upgrade naar de voyage-4-serie vereist een volledige her-embedding van de betreffende tabel zonder dat de live zoekfunctie breekt (dual-write of versiegescheiden migratie). **Triggercriterium:** Voyage kondigt een harde uitfaseerdatum aan voor een van beide modellen, of de kwaliteitswinst van voyage-4 wordt de moeite waard bevonden bij een gerichte test.
4. **Share intrekken:** Gebouwd maar bewust uitgesteld. Kleine kans op probleem bij huidige doelgroep.
5. **Pro-upgrade triggers bij 50 actieve gebruikers:** Vercel Firewall aanzetten, Clerk inactivity timeout + session limits aanscherpen. Supabase PITR heeft een eigen, hogere drempel (150 gebruikers), al automatisch bewaakt via de Abacus-kostencalculator.
6. **Clerk `createRouteMatcher()`:** gedeprecate sinds 7.5.14 t.g.v. `auth.protect()` per route, nog niet gemigreerd in `proxy.ts`. Geen harde deadline.
7. **Clerk TLS-cipher-deadline:** 18 januari 2027, vermoedelijk geen actie nodig, vlak vóór de deadline nog een keer bevestigen.
8. **Anthropic API-key-rotatie:** harde deadline 6 januari 2027 voor zowel arnobot als salescanvas-app.
9. **`/api/admin/export` vs `/api/admin/export-csv`:** opgelost (2026-08-21). Beide routes blijven bestaan (verschillend gebruik: JSON voor client-side PDF-opbouw vs. directe CSV-download), maar de gedupliceerde auth/fetch-logica is samengevoegd in `lib/adminExport.ts`.
0. **`/api/test/email-preview`:** geen actie nodig. Heeft wel een auth-check en is een bewust behouden, admin-only diagnosetool (2026-08-12).
1. **Geen betalingsprovider-koppeling — bewust pending:** `/api/admin/payment` zet alleen `paid_at` / `is_active`, facturatie zelf loopt volledig handmatig buiten deze codebase. Geen technisch gebrek maar een bewuste procesconditie bij de huidige schaal. **Triggercriterium:** binnen 30 dagen na de commerciële livegang (Arno's eigen toezegging 2026-08-21), niet gekoppeld aan een gebruikersaantal-drempel zoals de overige Pro-upgrade-triggers hierboven. Livegang-

datum zelf staat elders in dit document als uitgesteld/onzeker genoteerd, dus deze deadline schuift daarmee automatisch mee.